Security at GitLab

Security Vision and Mission

Our vision is to transparently lead the world to secure outcomes.

Our mission is to enable everyone to innovate and succeed on a safe, secure, and trusted DevSecOps platform. This will be achieved through 5 security operating principles:

1. Accelerate business success with a focus on:
    - Prioritize 'boring', iterative solutions that minimize risk
    - Find ways to say Yes
    - Understand goals before recommending solutions
    - Use GitLab first
2. Efficient operations with a focus on:
    - Technical controls over handbook rules
    - Leverage automation first (robots over humans)
    - Responsible decisions (Spending, Tooling, Staffing, etc) over low ROI (return on investment) decisions
    - Reusable or repeatable over singular solutions
3. Transparency with a focus on:
    - Responsible protection of MNPI (material non-public information)
    - Evangelize dogfooding of GitLab publicly
    - Lead with metrics
    - Balance security with usefulness
4. Risk Reduction with a focus on:
    - Secure by default
    - Preventative controls over detective controls
    - Solving root causes over treating symptoms
    - Visibility through Coverage, Discoverability, Observability
5. Collaborative Culture with a focus on:

    - Working together on common solutions
    - Solve shared problems with shared solutions
    - Simplifying language for everyone to understand
    - Avoiding security jargon
    - Seek opportunities to help others succeed
6. Scaling through enablement and usage of AI:
    - Enable safe AI adoption at speed for the enterprise and platform
    - Deploy AI to detect and prevent threats faster and automate workflows and processes
    - Embrace and incorporate AI productivity tooling to work smarter each day

Division Structure

The Security Division provides essential security operational services, is directly engaged in the development and release processes, and offers consultative and advisory services to better enable the business to function while minimising risk.

To reflect this, we have structured the Security Division around four key tenets, which drive the structure and the activities of our group. These are :

Product Security	Security Operations	Corporate Security	Security Assurance
• Application Security • Infrastructure Security • Security Platforms and Architecture • Vulnerability Management • Data Security	• Security Incident Response Team (SIRT) • Trust and Safety • Red Team • Threat Intelligence • Signals Engineering • Security Logging	• Corporate Security • Helpdesk Support • Tech Stack Systems • Engineering Teams	• Field Security • Security Compliance • Security Governance • Security Risk

---

Secure the Product - The Product Security Department

The Product Security Department is primarily focused on Securing the Product. This reflects the Security Division's current efforts to be involved in the Application development and Release cycle for Security Releases, Infrastructure Security, and our HackerOne bug bounty program.

The term “Product” is interpreted broadly and includes the GitLab application itself and all other integrations and code that is developed internally to support the GitLab application for the multi-tenant SaaS. Our responsibility is to ensure all aspects of GitLab that are exposed to customers or that host customer data are held to the highest security standards, and to be proactive and responsive to ensure world-class security in anything GitLab offers.

Protect the Company - The Security Operations Department

Security Operations Department teams are primarily focused on protecting GitLab the business and GitLab’s platform. This encompasses protecting company property as well as to prevent, detect and respond to risks and events targeting the business and our platform. This department includes the Security Incident Response Team (SIRT) and the Trust and Safety team.

These functions have the responsibility of shoring up and maintaining the security posture of GitLab’s platform to ensure enterprise-level security is in place to protect our new and existing customers.

Assure the Customer - The Security Assurance Department

The Security Assurance Department is comprised of the teams noted above. They target Customer Assurance projects among their responsibilities. This reflects the need for us to provide resources to our customers to assure them of the security and safety of GitLab as an application to use within their organisation and as a enterprise-level SaaS. This also involves providing appropriate support, services and resources to customers so that they trust GitLab as a Secure Company, as a Secure Product, and Secure SaaS

Protect the Organization - Corporate Security

GitLab is both a company and a product. The Corporate Security department focuses on implementing and protecting the information technology (IT) related systems that the company uses to conduct business internally, and provides the hardware, software, and tools that our team members and 3rd party service providers (aka contractors) need to be productive and get their job done efficiently. The configurations that we implement for team members internally are designed to protect our customers and their data.

We have a 24x5 technical support helpdesk for team members and have engineers that configure and maintain many of our company-wide tech stack applications.

We invest heavily in device trust, identity management, and infrastructure governance to provide the highest level of security assurance for the administrators of our product and ensure all appropriate controls are in place when handling customer data.

Contacting the Team

Reporting vulnerabilities and security issues

For information regarding GitLab's HackerOne bug bounty program, and creating and scheduling security issues, please see our engaging with security page and our Responsible Disclosure Policy.

Reporting an Incident

If an urgent security incident has been identified or you suspect an incident may have occurred, please refer to Engaging the Security Engineer On-Call. Examples include, but are not limited to:

- Lost or stolen devices
- Leaked credentials
- Endpoint compromise or infection
- Exposure of sensitive GitLab data

GitLab provides a `panic@gitlab.com` email address for team members to use in situations when Slack is inaccessible and immediate security response is required.

This email address is only accessible to GitLab team members and can be reached from their gitlab.com or personal email address as listed in Workday. Using this address provides an excellent way to limit the damage caused by a loss of one of these devices.

Additionally if a GitLab team member experiences a personal emergency the People Group also provides an emergency contact email.

Ransomware

For an overview of the communication and response process for a suspected ransomware attack, please see our Responding to Ransomware page.

Receive notification of security releases

- To receive security release blog notifications delivered to your inbox, visit our contact us page.
- To receive release notifications via RSS, subscribe to our security release RSS feed or our RSS feed for all releases.

- For additional information regarding security releases, please visit the Delivery Team's security releases page.

Other Frequently Used GitLab.com Projects

Security crosses many teams in the company, so you will find `~security` labeled issues across all GitLab projects, especially:

- gitlab-foss
- gitlab
- infrastructure
- production

When opening issues, please follow the Creating New Security Issues process for using labels and the confidential flag.

Last modified April 24, 2026: updated external HB page for accuracy (eed43a98)

View page source - Edit this page - please contribute. CC BY-SA